가상 침해사고 시나리오

사고 유형	랜섬웨어(Ransomware) 감염 및 내부 중요 서버 암호화
발생 상황	특정 기업의 재무 담당자 PC가 피싱 메일을 통해 악성코드에 감염된 후, 사내 공유 서버(NAS)까지 감염되어 주요 문서가 암호화되고 랜섬노드트(요구서) 출력

1단계. 사고 전 준비

- 보안 담당자는 사내 침해사고 대응팀(CERT)을 구성하고 연락망을 유지
- 정기적인 백업 정책에 따라 주요 서버의 데이터는 오프라인 백업(외부 저장소)으로 이중화
- 임직원 대상 상시 보안 교육(피싱 메일 훈련) 진행

2단계. 사고 탐지

- EDR 솔루션에서 재무 담당자 PC의 비정상적인 대량 파일 암호화 행위를 탐지
- EDR 시스템은 보안 담당자에게 실시간 긴급 긴급 경보를 발령과 동시에 사내 공용 서버(NAS) 모니터링 시스템에서 "파일 확장자가 .locked로 일괄 변경되었다"는 알림이 관제 모니터(또는 대시보드 화면)로 전송

3단계. 초기 대응

- **초기 조사 및 정황 기록**

  - 보안 담당자는 EDR 솔루션을 통해 재무 담당자 PC에서 대량의 파일 암호화가 시작된 정확한 시각과 대상 시스템(NAS 서버)의 IP를 긴급히 기록

- **대응팀(CERT) 소집 및 통지**

  - 즉시 사내 침해사고 대응팀을 소집하고, 인프라 관리 부서 및 임원진에게 랜섬웨어 감염 사실을 통지하여 비상 체계에 돌입

- **물리적/논리적 격리**

  - 추가적인 확산을 저지하기 위해 감염된 재무 담당자 PC의 랜선(네트워크)을 즉시 뽑고, 사내 공유 서버의 외부 및 내부 네트워크 연결을 일시 차단했습니다.

4단계. 대응 전략 체계화

초기 조사 결과를 바탕으로 가장 적절한 방어 및 수습 전략을 수립하고 경영진의 승인을 받는 단계

- **피해 규모 및 영향 평가**

  - 재무 서버가 마비됨에 따라 당장 부서 업무가 중단되는 비즈니스 리스크를 산정

- **대응 시나리오 결정**

  - 랜섬웨어 공격자에 대한 대가(암호 화폐) 지불 여부는 기업 정책에 따라 '절대 불가'로 선언하고 백업을 통한 복원 방향으로 가닥을 잡음

- **법적 신고 및 수사기관 공조 판단**

  - 피해 규모가 크고 외부 해킹 조직의 소행으로 의심되므로, 정보통신망법 등에 따른 KISA 의무 신고 및 경찰(사이버수사대) 수사 의뢰를 진행하기로 전략을 세우고 경영진의 최종 승인을 획득

5단계. 사고 조사

- **디지털 증거 수집**

  - 감염된 PC와 공유 서버의 디스크 이미징을 뜨고, 네트워크 트래픽(PCAP) 및 시스템 로그를 안전하게 백업하여 증거 멸실 방지

- **침투 경로 역추적**

  - 포렌식 분석을 통해 재무 담당자가 열어본 피싱 메일 속 첨부파일의 악성코드 해시값 추출
  - 해당 파일이 사내 방화벽을 우회해 외부 C&C 서버와 통신한 로그를 확보

- **공격 행위 분석**

  - 공격자가 취약한 원격 접속(RDP) 계정을 이용해 내부망으로 진입한 뒤 관리자 권한을 탈취해 랜섬웨어를 실행했다는 전체 공격 라이프사이클(Kill Chain)을 규명

7단계. 해결

- 무결성 및 백업 검증
  - 3단계와 5단계 조치를 통해 악성코드와 취약점이 완전히 제거된 것을 확인 후
  - 랜섬웨어 감염 이전에 안전하게 분리 보관 중인 오프라인 백업본의 무결성(손상 여부)을 검증

- 데이터 및 시스템 복원
  - 공유 서버(NAS)에 백업 데이터를 주입하여 최신 상태로 데이터를 복구하고,
  - 재무 담당자 PC도 포맷 후 깨끗한 상태(Re-image)로 재구축

- 정상 가동 테스트 (Smoke Test)
  - 복구 직후 곧바로 전사 업무를 재개하지 않고, 재무 부서 담당자와 함께 핵심 재무 문서 조회, 편집, 저장 및 권한 설정 등이 정상적으로 작동하는지 철저한 합동 테스트를 진행

6단계. 문서화

- 사고 발생 시각, 탐지 경로, 피해 규모, 대응 타임라인, 원인 분석 결과 및 복구 내역을 상세히 기록한 최종 침해사고 보고서를 작성하여 경영진에게 보고
- 또한 관련 법령(개인정보보호법 및 정보통신망법)에 따라 관계 기관(KISA 등)에 법정 기한 내에 신고를 완료